

抓包



黑马程序员
www.itheima.com

传智教育旗下
高端IT教育品牌



网络基础知识

黑马程序员·软件测试

网络访问过程

1. 用户在浏览器上输入URL地址：
<http://www.itheima.com>，按下回车

2. 浏览器以特定方式把**请求**发送给服务器，请求黑马程序员的首页内容

3. 服务器根据请求信息，
查找用户需要的数据内容

<http://www.itheima.com>



5. 客户端接收到数据之后，
把最终结果显示在浏览器中

黑马程序员首页

4. 服务器找到想要请求的数据后，
将数据以特定方式返回给客户端

请求：从客户端发送到服务器的请求消息(2)

响应：从服务器返回给客户端的请求结果(4)

说明

请求和响应内容各自包括三个部分。



请求重点:

- URL
- 请求方法
- 请求参数 (请求体)

请求信息示例:



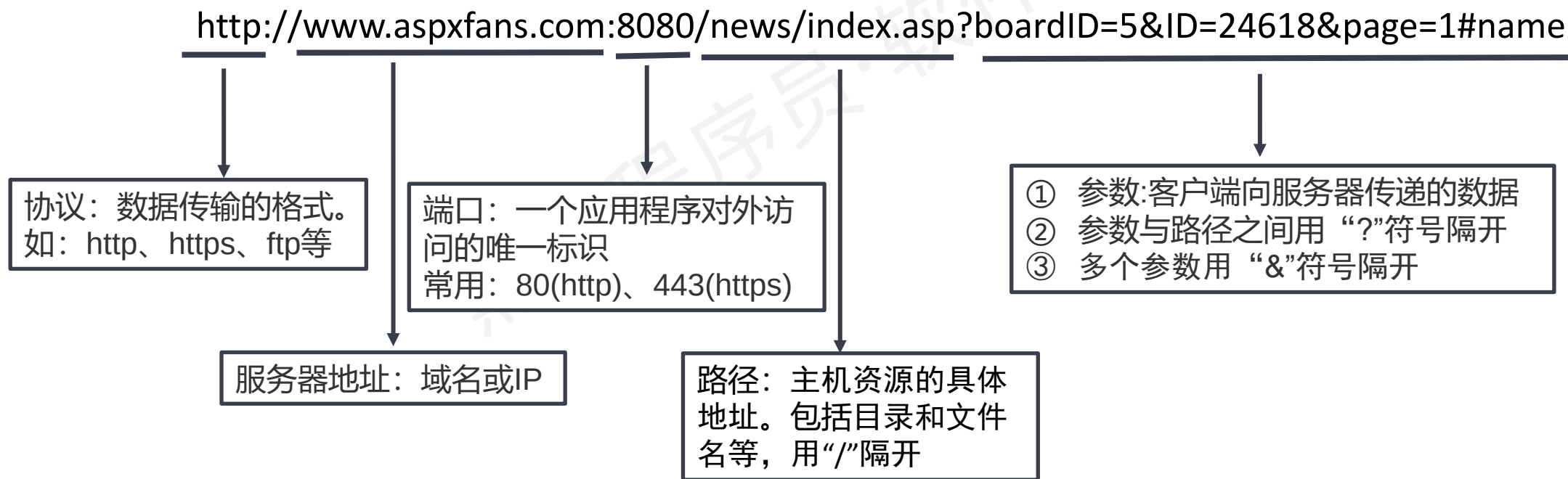
```
POST http://hmshop-test.itheima.net/index.php?m=Admin&c=Admin&a=login&t=0.6801899847919697 HTTP/1.1
Connection: keep-alive
Content-Length: 43
Accept: application/json, text/javascript, */*; q=0.01
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/92.0.4515.159 Safari/537.36
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Origin: http://hmshop-test.itheima.net
Referer: http://hmshop-test.itheima.net/index.php/Admin/Admin/login
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: gr_user_id=91c4617a-56ed-4a65-b94b-589c7ee187d8; CNZZDATA009=30037667-1536735; PHPSESSID=jdd4d4soqe134tabcmqgbelsn6; parent_re

username=admin&password=123456&verify=8888
```

1.URL

URL (网址) = 协议://主机地址(IP地址或域名):端口号/路径?参数名=参数值&参数名=参数值

示例:



2. 请求方法

HTTP请求中有两个最常见的请求方法：GET和POST

3. 请求参数

格式：参数名=参数值

注：多个参数用“&”连接

示例：



```
username=admin&password=123456&verify=8888
```

参数名=参数值



案例

使用浏览器开发者工具分析登录请求信息

需求:

- 请求URL地址
 - 协议
 - 域名
 - 端口号
 - 资源路径
- 请求方法
- 请求参数

账户登录

8888

[忘记密码?](#)

登录

1、鼠标右键一检查 或 F12 打开浏览器开发者工具

2、切换到【网络】页面，查看页面请求和响应信息

3、勾选保留日志

4、选择页面对应数据包

5、标头：查看URL地址、请求方法、请求头、响应头等信息
载荷：查看请求体信息
响应：查看响应信息

名称

index.php?m=Home&c=User&a=do_login&t=0.84297334768...

login.html

index.html

tpshop.css

jquery-1.11.3.min.js

layer.js

base.css

global.js

location.css

标头

载荷

预览

响应

启动器

时间

Cookie

▼ 查询字符串参数

m: Home
c: User
a: do_login
t: 0.8429733476856178

▼ 表单数据

username: 1348888888
password: 123456
verify_code: 8888

26 个请求

已传输 110 kB

689 kB 项资源

完成用时: 5.25 秒



响应重点:

- 响应状态码
- 响应体

响应内容示例:



Transformer	Headers	TextView	SyntaxView	ImageView	HexView	WebView	Auth	Caching	Coo
HTTP/1.1 200 OK									
Server: nginx									
Date: Thu, 30 Sep 2021 01:56:23 GMT									
Content-Type: text/html; charset=UTF-8									
Connection: keep-alive									
Vary: Accept-Encoding									
Vary: Accept-Encoding									
X-Powered-By: PHP/5.6.40									
Expires: Thu, 19 Nov 1981 08:52:00 GMT									
Pragma: no-cache									
Cache-control: private									
Content-Length: 53									
{\"status\":1,\"url\":\"\\index.php\\Admin\\Index\\index\"}									

1. 响应状态码

响应状态码是用数字表示的响应状态，最常见的有4种类型



HTTP响应-常见响应状态码

状态码	状态消息	说明
200	OK	服务器成功返回用户请求的数据
201	CREATED	用户新建或修改数据成功
204	NO CONTENT	用户删除数据成功
301	Moved Permanently	被请求的资源已永久移动到新位置
302	Move Temporarily	被请求的资源临时性移动到新位置
400	Bad Request	客户端请求有语法错误，不能被服务器所理解
401	Unauthorized	未授权的（未登录）
403	Forbidden	表示用户得到授权，但是访问是被禁止的
404	Not Found	请求资源不存在
500	INTERNAL SERVER ERROR	服务器发生错误，用户将无法判断发出的请求是否成功
503	Server Unavailable	服务器当前不能处理客户端的请求，一段时间后可能恢复正常

2. 响应体

响应体：服务器返回给客户端的数据内容。常见内容：**HTML**、**Json**、**TXT**、图片等

响应体示例：

```
{"status":1,"url":"\\/index.php\\/Admin\\/Index\\/index"}
```

Json格式

```
Content-Length: 56894
<!doctype html>
<html>
<head>
<meta http-equiv="content-type" content="text/html; charset=UTF-8">
<meta charset="utf-8">
<meta http-equiv="X-UA-Compatible" content="IE=edge">
<meta name="viewport" content="width=device-width, initial-scale=1.0, maximum-scale=1.0, user-scalable=no">
<!-- Apple devices fullscreen -->
<meta name="apple-mobile-web-app-capable" content="yes">
<!-- Apple devices fullscreen -->
<meta name="apple-mobile-web-app-status-bar-style" content="black-translucent">
<link rel="shortcut icon" type="image/x-icon" href="/public/static/images/logo/storeico_default.png" media="screen"/>
<title>TPshop开源商城</title>
<script type="text/javascript">
    var SITEURL = window.location.host + '/index.php/admin';
</script>
<link href="/public/static/css/main.css" rel="stylesheet" type="text/css">
```

HTML格式

案例

使用浏览器开发者工具分析登录响应信息

需求:

- 响应状态码
- 响应体

账户登录

	手机号/邮箱
	密码
验证码	

[忘记密码?](#)

登 录

练习

使用浏览器开发者工具分析搜索商品请求和响应信息

 搜索

手机 小米 iphone 三星 华为 冰箱

需求：

- 请求URL地址
 - 协议
 - 域名
 - 端口号
 - 资源路径
- 请求方法
- 请求参数
- 响应状态码
- 响应体

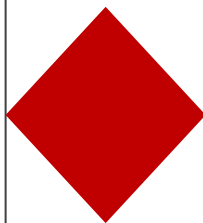
相同点

- 都可以向服务器发送请求，并携带参数

不同点（面试题）

GET

- GET请求参数放在URL里（在浏览器地址栏中可以直接看到）
- URL本身有长度限制（每个浏览器不同），参数数量不能过多
- 例如：tpshop前台搜索商品



POST

- POST请求参数放在请求体里（抓包才能看到）——相对安全
- 消息体本身没有长度限制，因此POST请求可以传递任意数量的参数
- 例如：tpshop前、后台登录

总结

1. HTTP请求

URL: 协议://主机地址(IP地址或域名):端口号/路径?参数名=参数值&参数名=参数值

请求方法: get和post, 都可以发送数据携带参数

get:

参数放在URL里
有长度限制

post:

参数放在请求体里
无长度限制

请求体: 参数名=参数值&

2. HTTP响应

响应状态码:

2XX: 成功

3XX: 重定向

4XX: 客户端错误

5XX: 服务器错误

响应体: HTML、JSON



02

测试辅助工具（抓包工具）



学习目标

Learning Objectives

- ◆ 能操作抓包工具抓取http请求和响应的数据包
- ◆ 能操作抓包工具进行弱网测试
- ◆ 能使用抓包工具绕过页面限制进行测试

思考

问题：用户在商城上购买商品并且支付，页面提示支付成功；但是在我的订单中却找不到该订单记录？



下单支付

增加商品信息和支付信息



数据库



我的订单

调用数据库信息



- **抓包** (packet capture)：使用工具抓取客户端与服务器交互**数据包**的操作。

- 数据包：客户端与服务器相互交互的内容。

- 常见抓包工具：F12, **Charles**, Fiddler等

- 为什么抓包？

- 定位前后端bug

- 弱网测试

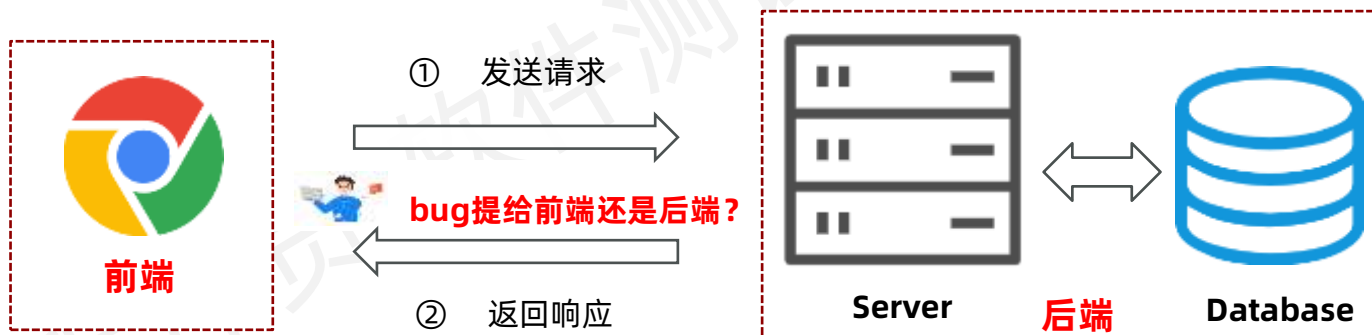
- 绕过界面限制进行测试

- 如何区分前后端 bug？

- ① 如果抓不到请求或请求有误是前端问题；

- ② 如果有请求但是没响应，那就是后端的问题；

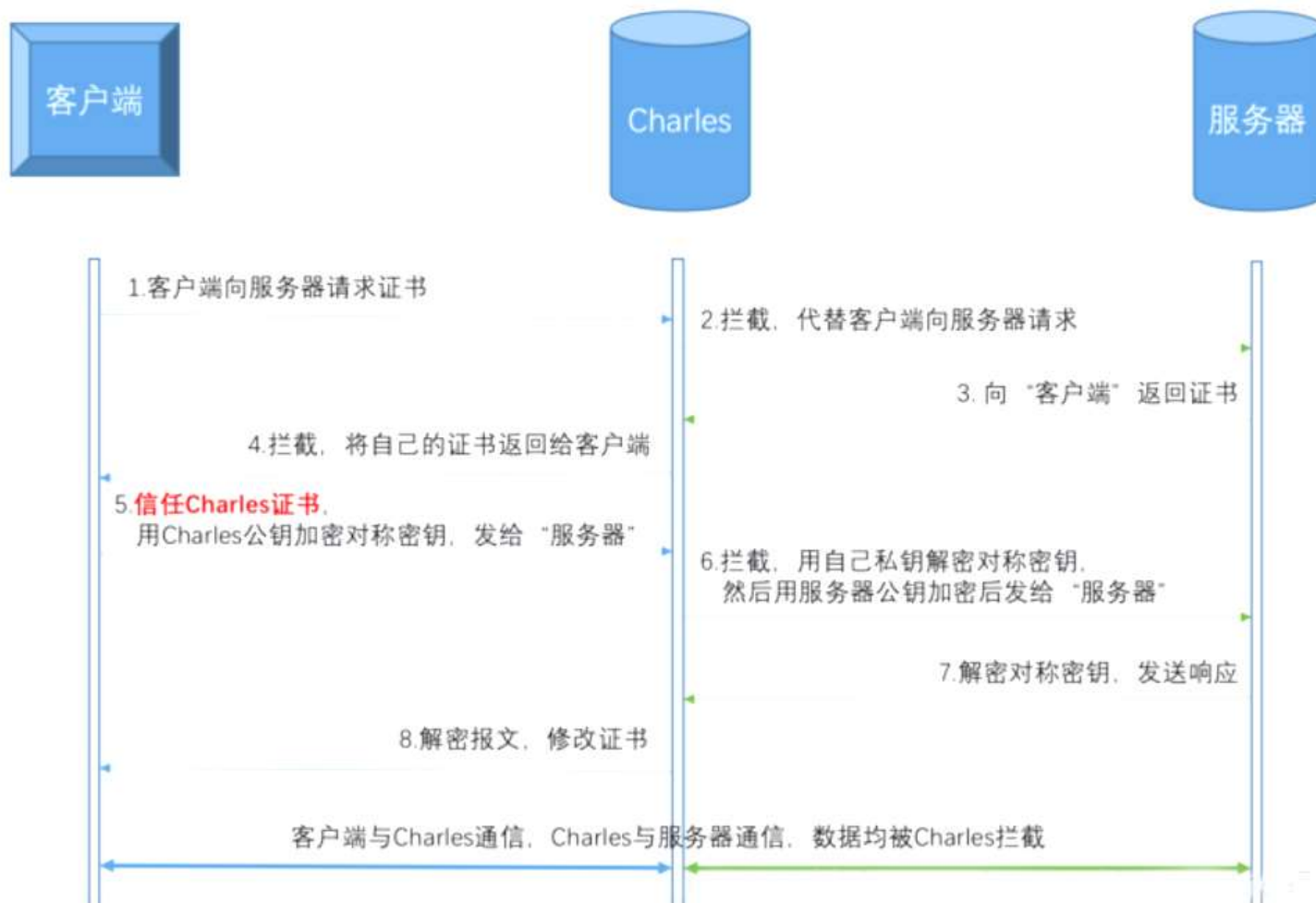
- ③ 如果有请求也有响应，需要查看响应信息，如果返回报错了，则需要具体分析报错内容。



➤ 工具介绍:

Charles是一款在**Mac**下常用的数据包截取工具，在做移动开发时，为了调试移动端与服务端的网络通讯协议，常常需要截取网络数据包来进行分析。

➤ 抓包的原理:



案例 使用抓包工具判断“后台添加的会员在前台显示时性别错误问题”

会员管理 - 添加会员 网站系统添加会员

* 会员昵称 jack

* 登录密码 123456
6-16位字母数字符号组合

* 手机号码 13477777777
前台登陆账号, 手机邮箱

* 邮件地址
前台登陆账号, 手机邮箱任意一项都可以

QQ

性别 ☒ 保密 ☐ 男 ☐ 女

确认提交



个人信息

头像:

昵称: jack

性别: ☐ 保密 ☐ 男 ☒ 女

生日: 1970-01-01

手机 未绑定 邮箱 未绑定

注: 修改密码、手机等信息到 [安全设置](#)

确认保存



思考

1.带宽1M和带宽100M打开tpshop网站效果一样吗?

2.手机使用2G网络和使用3G网络打开京东的效果一样吗?

弱网环境下可能会出现的异常

- 上传文件时进度卡住不动
- 登录不上或者登录后立即掉线
- 响应过程中页面控件可点击，导致崩溃
- 搜索不响应，多次点击后结果显示总在刷新被替换



2.弱网测试

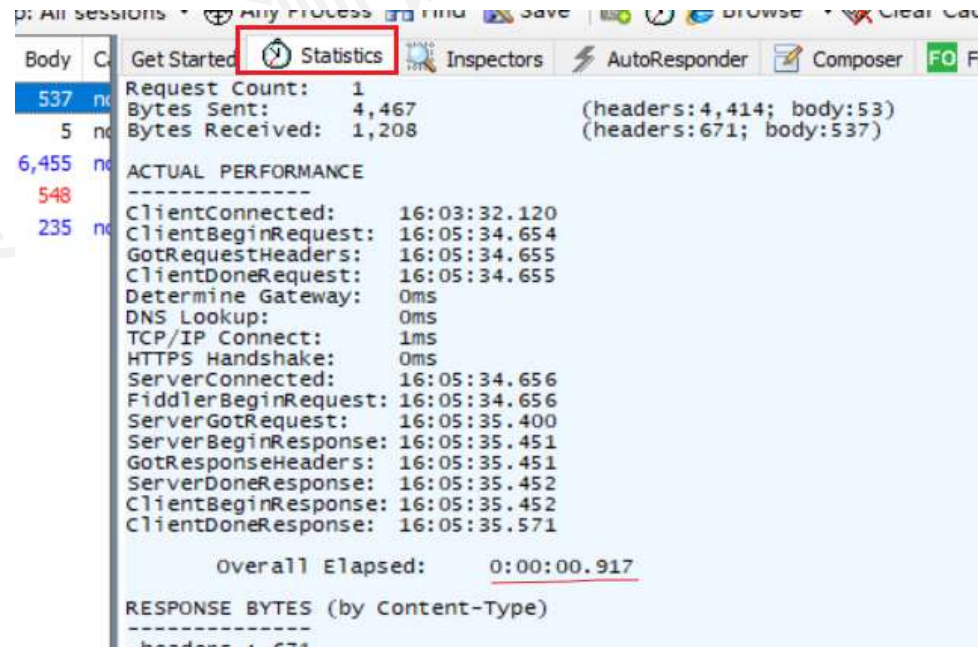
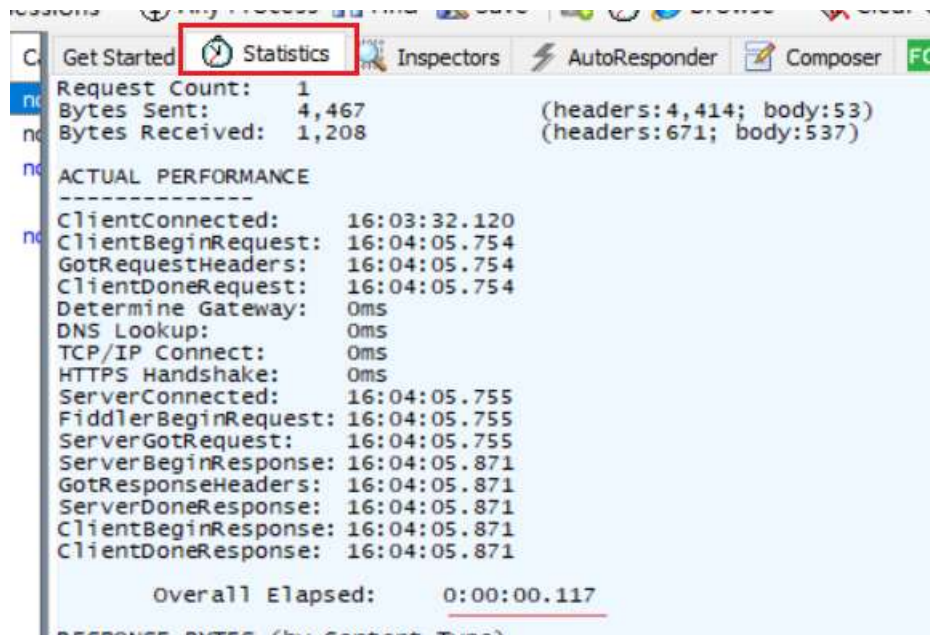
步骤：

- 1.设置要模拟的网络速度
- 2.开启网络延时
- 3.测试项目

黑马程序员·软件测试

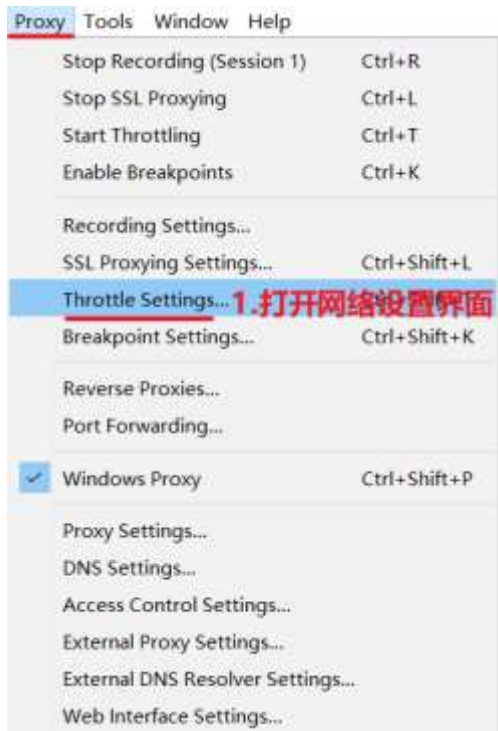
练习

使用抓包工具，针对tpshop登录功能进行弱网测试，查看上行值100，下行值50时，延时多少？是否有异常？

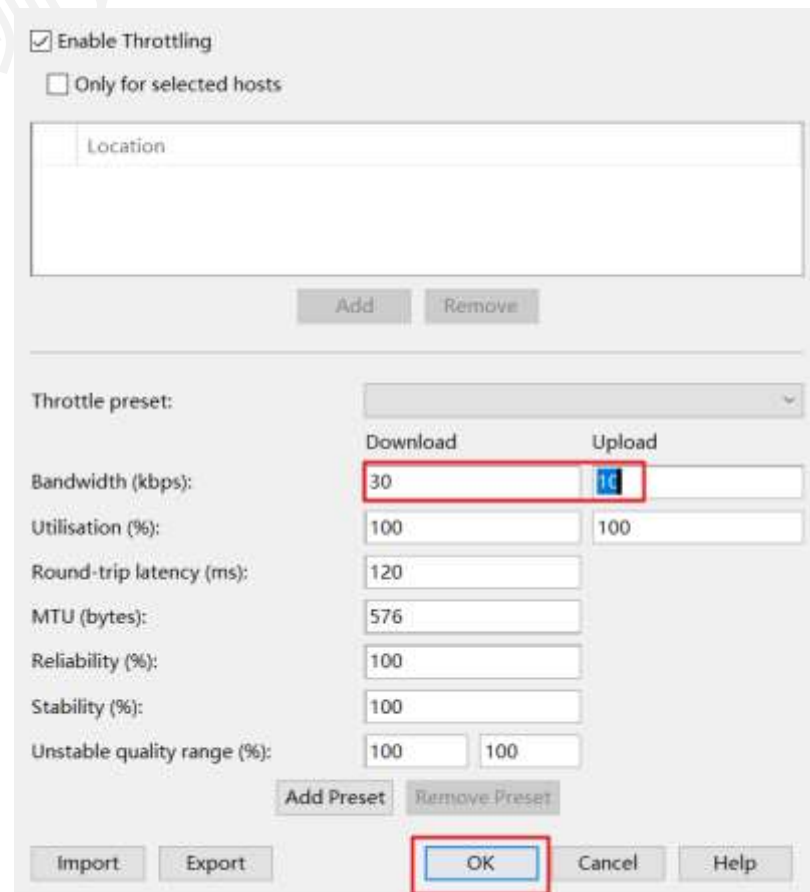


➤ 弱网测试方法

1. SIM卡网络切换
2. 实际弱网场景测试（地铁、电梯、停车场）
3. 使用软件进行网络代理（Charles）
 - ① 保证抓包成功（参考抓包教程）
 - ② Charles打开弱网设置配置项（Proxy→Throttle Settings）
 - ③ 设置带宽值



网络	上行	下行
弱网	10	30
2G	15	50
3G	384	2800



➤ 弱网测试

- 前置：使用adb命令清除缓存
- 示例：**adb shell pm clear com.tpshop.malls**

```
C:\Users\Jack>adb shell pm clear com.tpshop.malls
Success

C:\Users\Jack>_
```



网络带宽值（速度）参考

常用带宽信息表									
2G网络					3G网络				
	上行（MHz）	下行（MHz）	上行速率（bps）	下行速率（bps）		上行（MHz）	下行（MHz）	上行速率（bps）	下行速率（bps）
GSM900	890~915	935~960	2.7k	9.6k	CDMA2000	825~835	870~880	1.8m	3.1m
EGSM900	880~890	925~935	2.7k	9.6k	TD-SCDMA	1880~1920	2010~2025	384m	2.8m
GSM1800	1710~1785	1805~1880	2.7k	9.6k	WCDMA	1920~1980	2110~2170	5.76m	7.2m
GSM1900	1850~1910	1850~1990	2.7k	9.6k					

例如：

上行： $[1/(2.7/8)]*1000=2962\text{ms}$

下行： $[1/(9.6/8)]*1000=833\text{ms}$

思考

问题：为什么要绕过界面限制做测试？

原因：界面限制导致部分异常数据无法输入



3. 绕过界面限制直接测试服务器

步骤：

1. 设置断点
2. 修改请求
3. 修改响应

黑马程序员·软件测试



案例

使用抓包工具设置断点，验证tpshop登录账号为空时的结果

黑马程序员·软件测试



使用抓包工具设置断点，将tpshop商城首页title改为 “Testing”

黑马程序员·软件测试



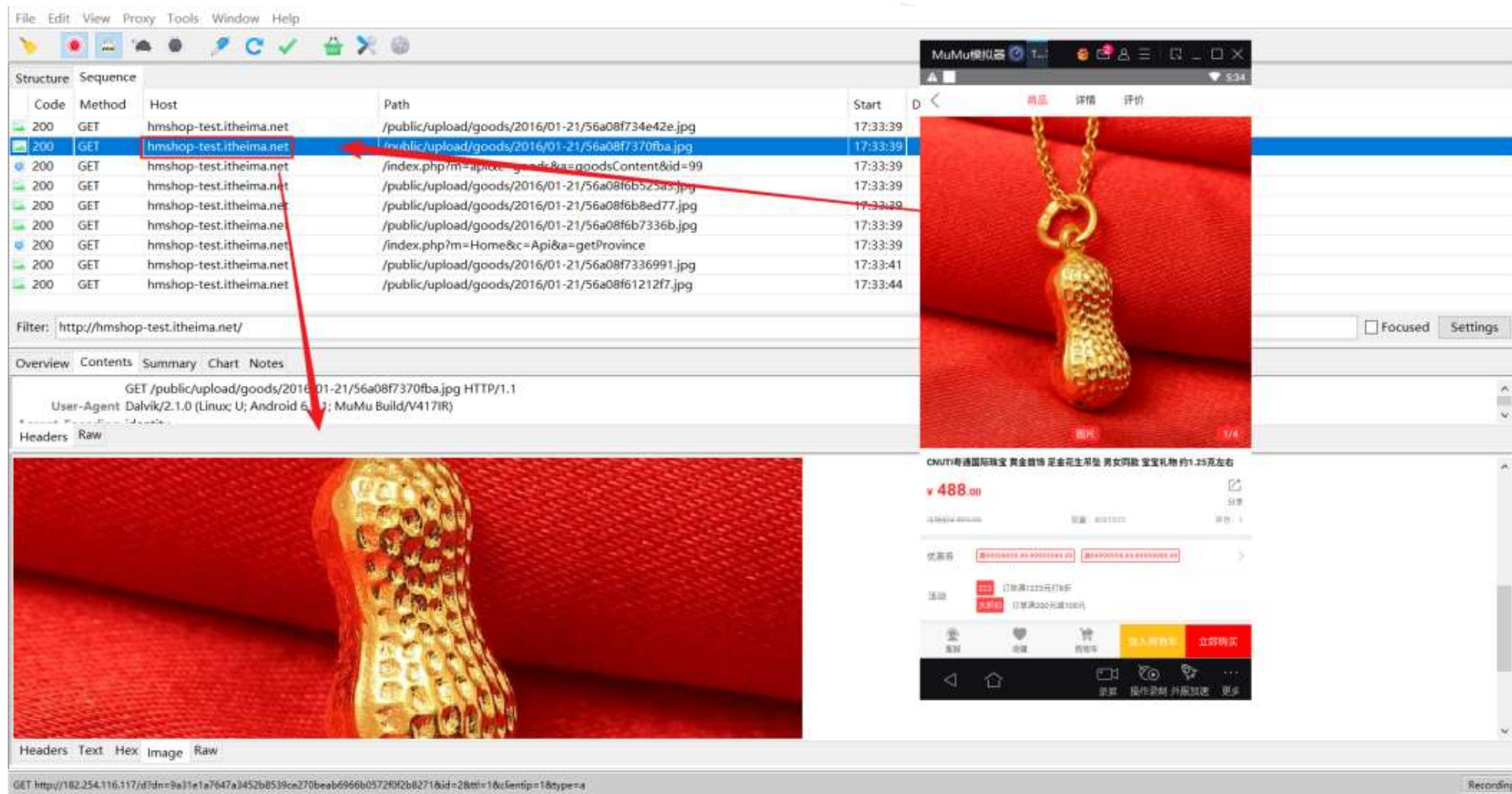
手机抓包

黑马程序员·软件测试

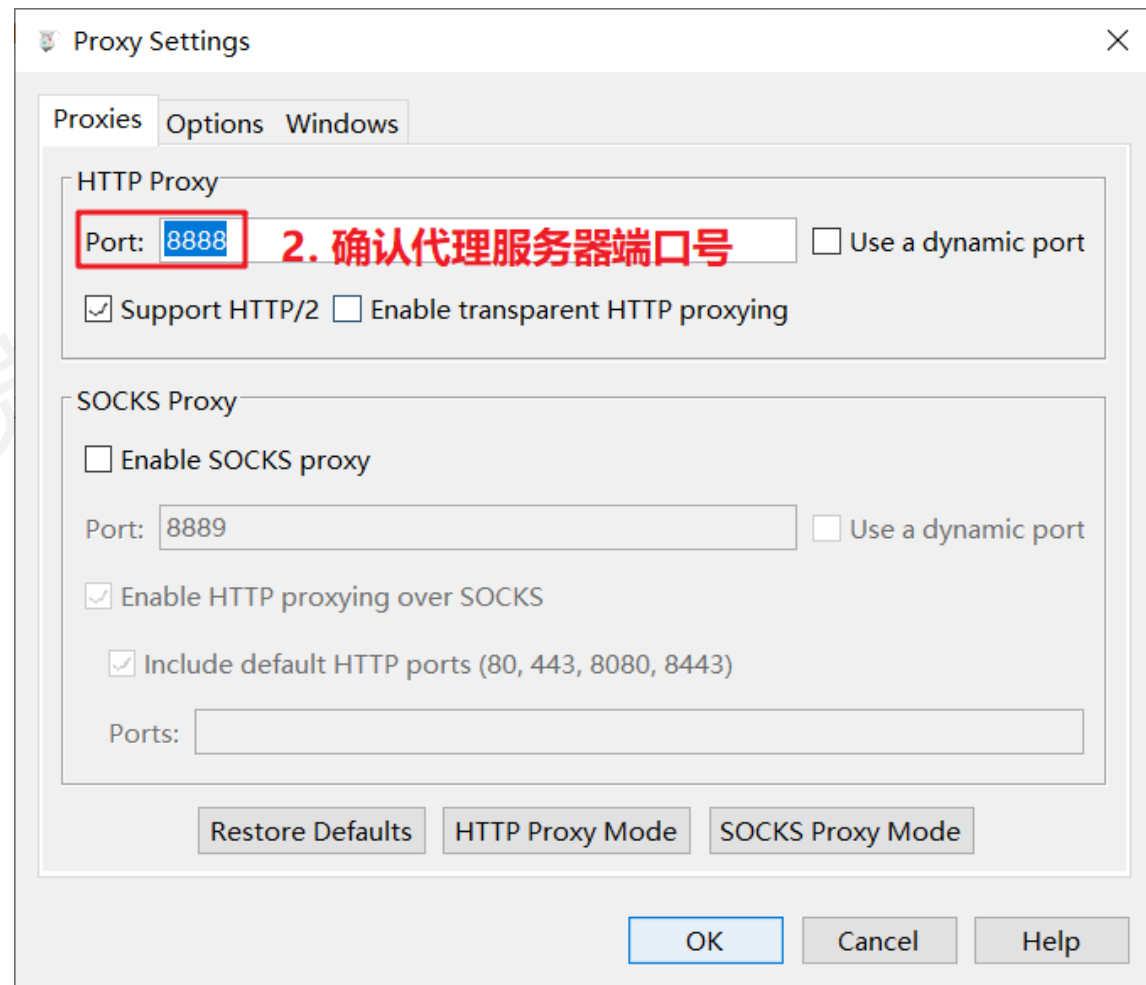
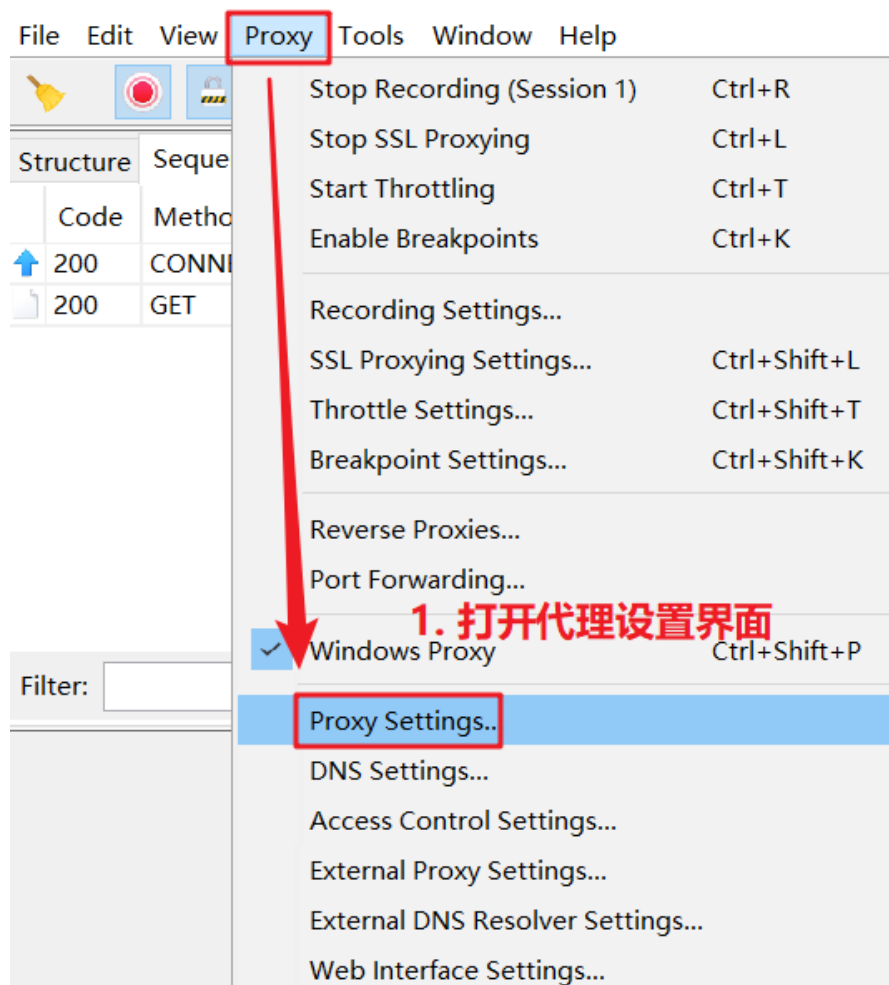
➤ 前置条件：手机和电脑保持同一网段（连接同一个WiFi）

➤ 操作步骤：

1. 设置代理
2. 安装证书
3. 手机抓包

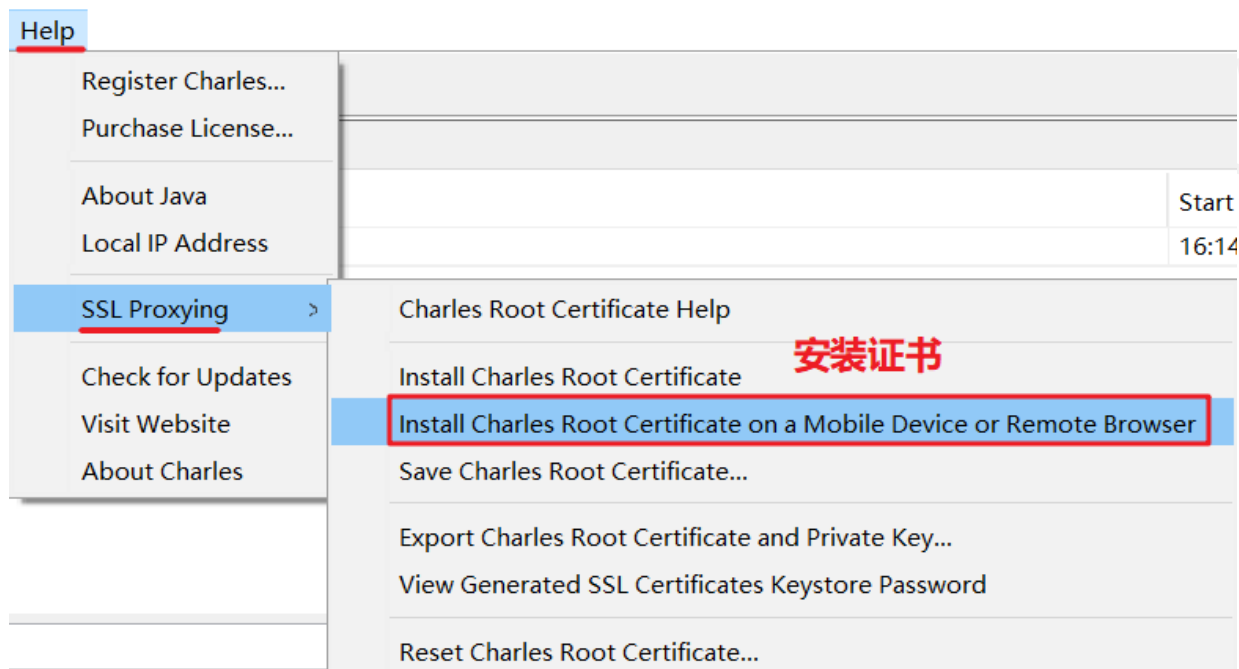


➤ 确认代理信息：Proxy->Proxy Sting->确认端口号



➤ 获取代理及证书信息：

① 点击Charles菜单栏**Help->SSL Proxying->install Charles Root Certificates on a Mobile Device or Remote Browser**,可以看到手机端安装证书提示；



Charles

1.手机上代理服务器设置信息



Configure your device to use Charles as its HTTP proxy on 192.168.3.13:8888, then browse to chls.pro/ssl to download and install the certificate.

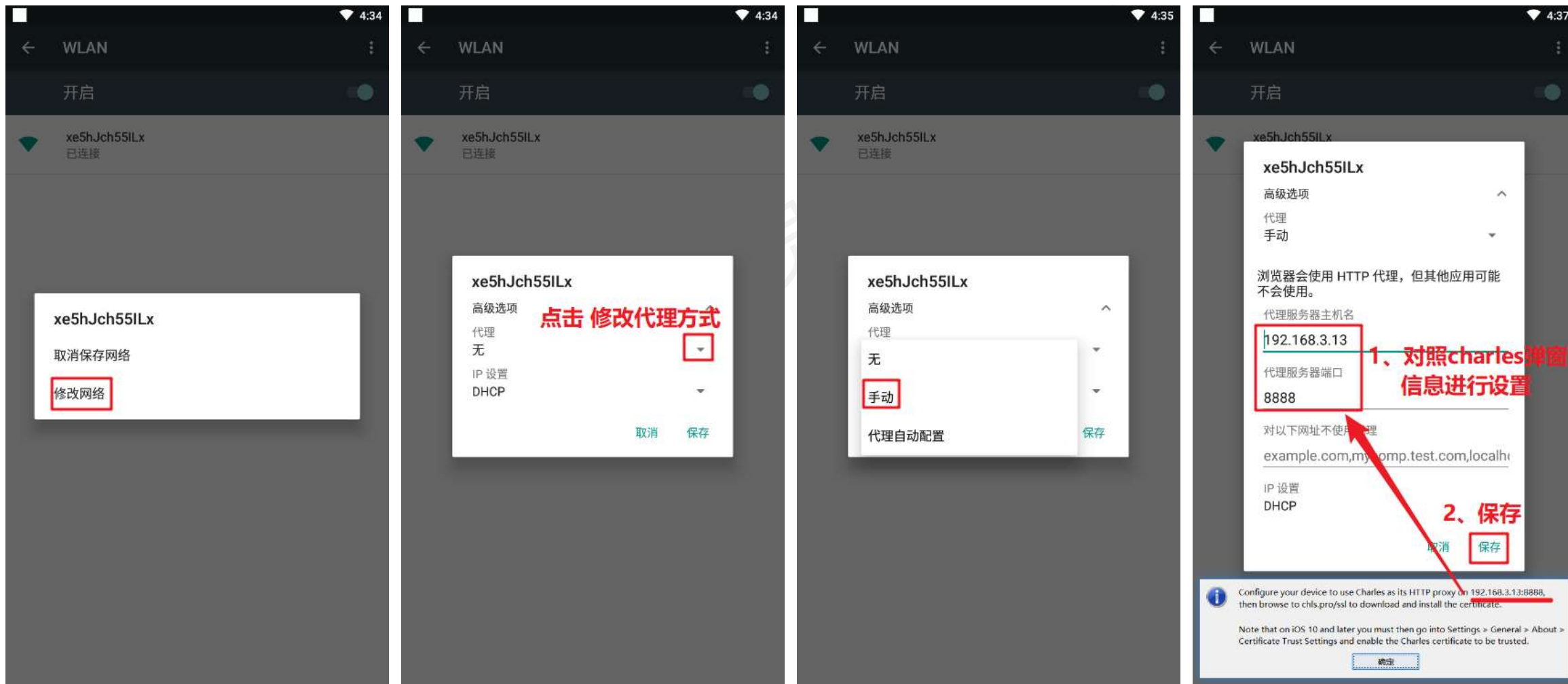
2. 手机证书下载地址

Note that on iOS 10 and later you must then go into Settings > General > About > Certificate Trust Settings and enable the Charles certificate to be trusted.

确定

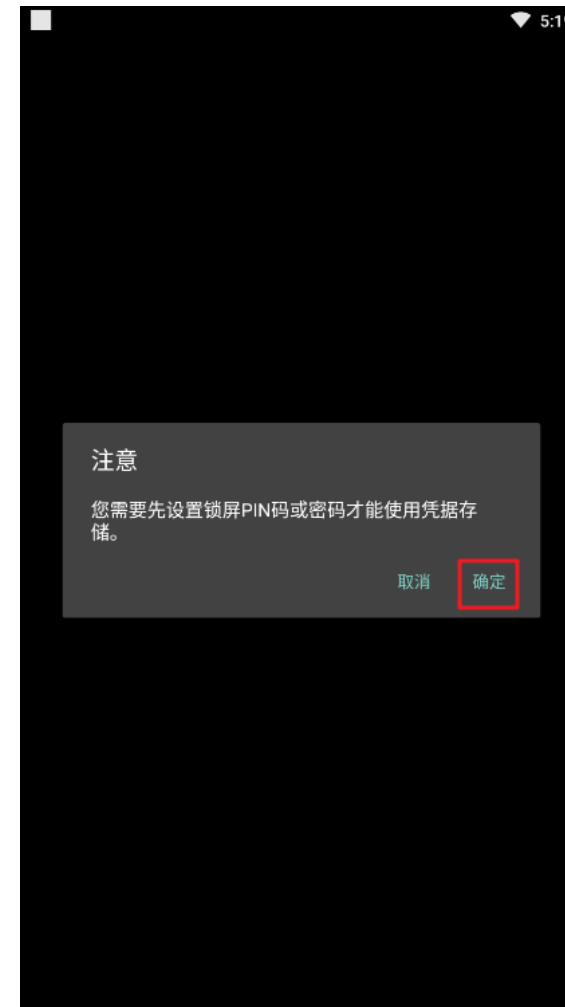
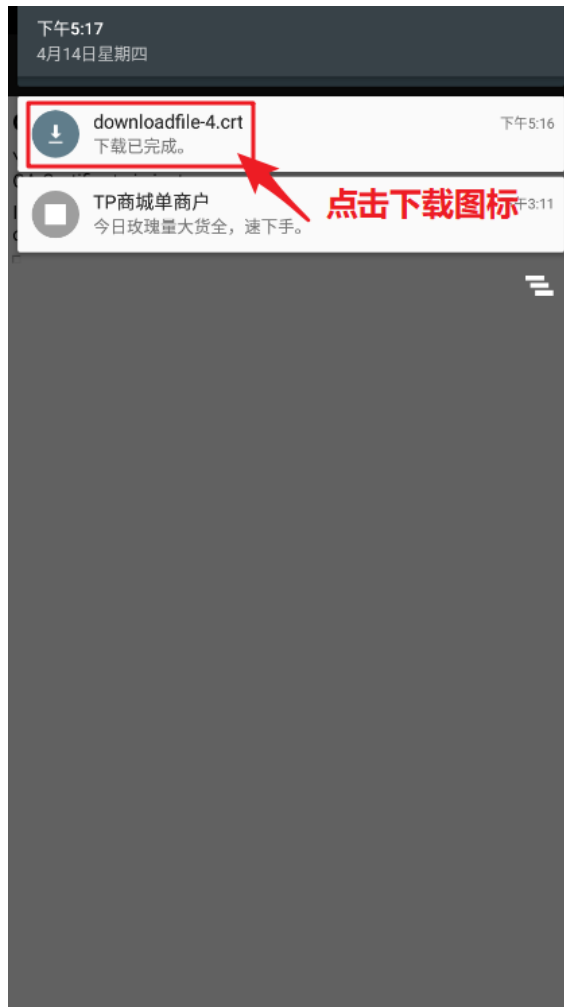
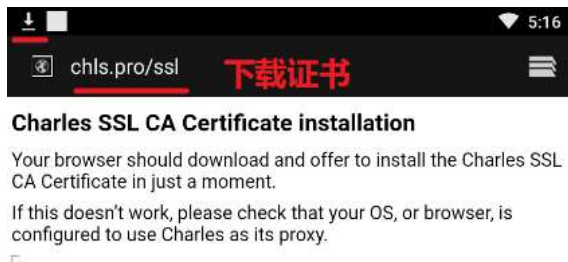
➤ 手机设置代理：

➤ 步骤：系统应用==》设置==》WLAN ==》长按网络连接==》修改网路



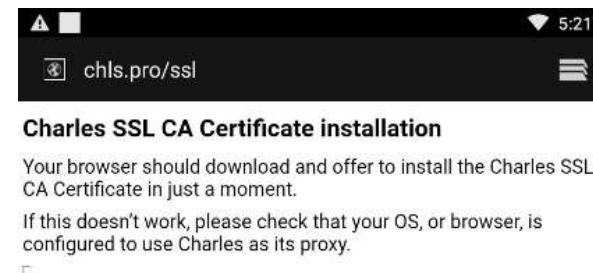
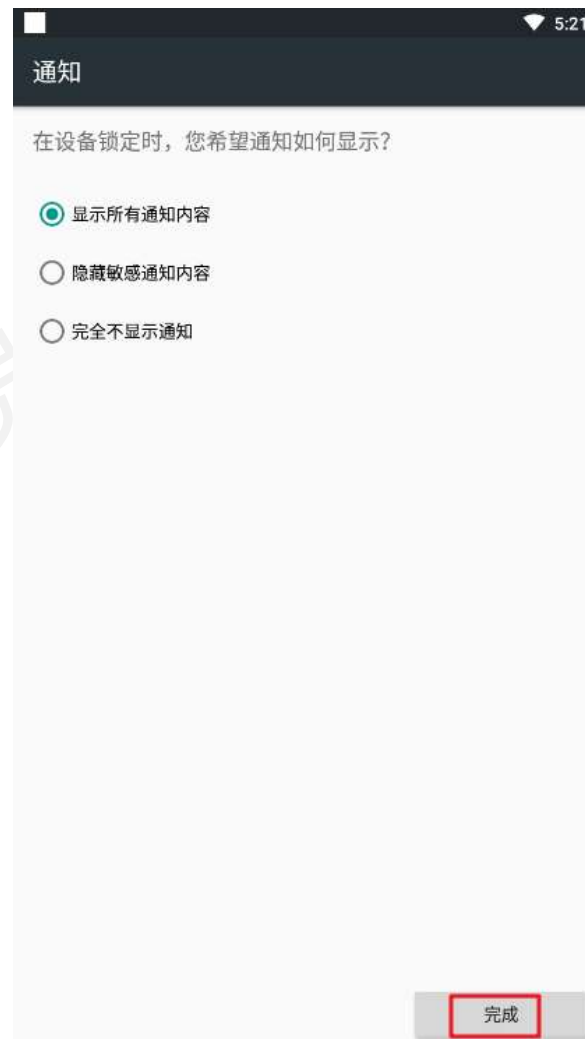
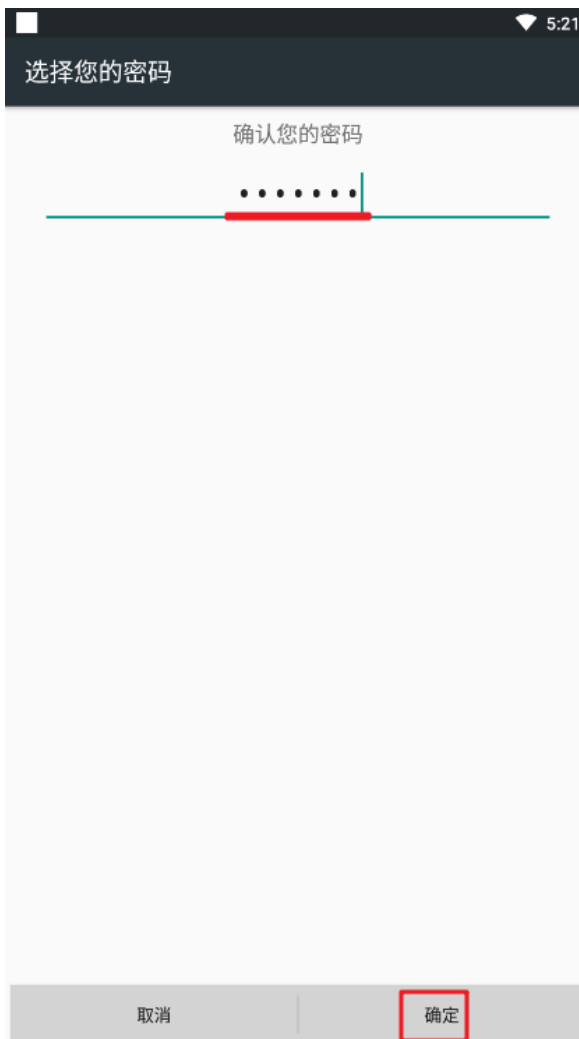
➤ 手机安装证书

➤ 步骤：手机浏览器访问网页，输入**chls.pro/ssl**，下载并安装。



➤ 手机安装证书

➤ 步骤：手机浏览器访问网页，输入**chls.pro/ssl**，下载并安装。



已安装 jack666。

➤ 手机抓包

The screenshot displays the Charles Proxy application on the left and the MuMu Android emulator on the right. In Charles, the 'Sequence' tab shows a list of HTTP requests. The second request is highlighted in blue, and a red box is drawn around its 'Host' field, 'hmshop-test.itheima.net'. A red arrow points from this box to the 'Host' field in the 'Raw' tab below. The 'Raw' tab shows the raw HTTP request: `GET /public/upload/goods/2016/01-21/56a08f370fba.jpg HTTP/1.1`. Below the raw request is a large image of a gold chain with a textured pendant. The MuMu emulator on the right shows a mobile app interface with a red background. At the top, it says '商品 详情 评价'. Below this is a large image of the same gold chain pendant. To the right of the image are buttons for 'Focued' and 'Settings'. Below the image, there is text: 'CNU71 粤通国际珠宝 黄金首饰 足金花生吊坠 男女同款 宝宝礼物 约1.25克左右', followed by the price '¥ 488.00'. There are also some promotional banners and a bottom navigation bar with icons for home, search, cart, and other functions.

Code	Method	Host	Path	Start
200	GET	hmshop-test.itheima.net	/public/upload/goods/2016/01-21/56a08f734e42e.jpg	17:33:39
200	GET	hmshop-test.itheima.net	/public/upload/goods/2016/01-21/56a08f370fba.jpg	17:33:39
200	GET	hmshop-test.itheima.net	/index.php?m=api&c=goods&a=goodsContent&id=99	17:33:39
200	GET	hmshop-test.itheima.net	/public/upload/goods/2016/01-21/56a08f6b525a3.jpg	17:33:39
200	GET	hmshop-test.itheima.net	/public/upload/goods/2016/01-21/56a08f6b8ed77.jpg	17:33:39
200	GET	hmshop-test.itheima.net	/public/upload/goods/2016/01-21/56a08f6b7336b.jpg	17:33:39
200	GET	hmshop-test.itheima.net	/index.php?m=Home&c=Api&a=getProvince	17:33:39
200	GET	hmshop-test.itheima.net	/public/upload/goods/2016/01-21/56a08f336991.jpg	17:33:41
200	GET	hmshop-test.itheima.net	/public/upload/goods/2016/01-21/56a08f61212f7.jpg	17:33:44

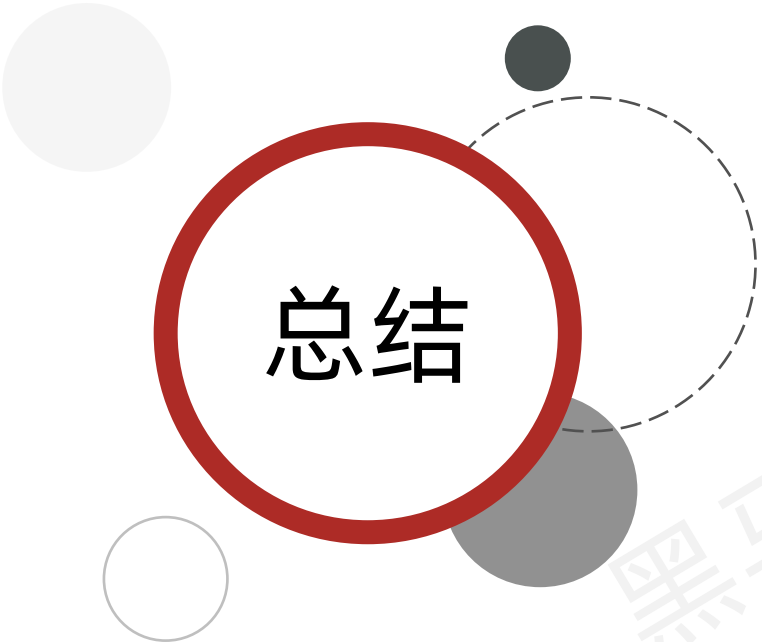
Filter: http://hmshop-test.itheima.net/

Overview Contents Summary Chart Notes

GET /public/upload/goods/2016/01-21/56a08f370fba.jpg HTTP/1.1
User-Agent: Dalvik/2.1.0 (Linux; U; Android 6.0.1; MuMu Build/V417IR)

Headers Raw

GET http://182.254.116.117/d?dn=9a31e1a7647a3452b8539ce270beab6966b0572f0f2b8271&id=28&w=1&c&entip=1&type=a



总结

(1) HTTP协议

- HTTP请求：请求行、请求头、请求体
- HTTP响应：响应行、响应头、响应体

(2) 抓包的三种使用场景

- 定位前后端Bug：若没有请求，则为前端bug；若有请求但是没响应，则为后端的bug；如果两个都有，具体分析响应数据。
- 弱网测试：设置要测试的网络值->开启延时->测试项目
- 绕过界面限制测试：设置断点->修改请求或者响应

(4) 常用抓包工具有哪些：

- Fiddler
- Charles
- Firebug等



传智教育旗下高端IT教育品牌